



Q+7LkMK05

SELF-ASSESSMENT AND TECHNICAL CONFORMITY REPORT v1.0

Internal engineering evidence package for the cryptographic platform snapshot.

Report ID	Q7-SELF-20260531-BDCEB8FA	Issued	2026-05-31 16:31:05 UTC-04:00
Git snapshot	1d727f3a6086f251b267ca49211620eb2907d86b	Version	Platform v12 / package 2.1.0
Snapshot digest	BDCEB8FA47CBBA44	Assessment type	Internal self-assessment

LEGAL AND TECHNICAL NOTICE: This document is an internal self-assessment issued by the Q+7LkMK05 project. It is not an official FIPS 140-3 validation, ISO/IEC 27001 certificate, SOC 2 examination, accredited laboratory result, penetration-test attestation, or legal guarantee of security.

Executive statement

Q+7LkMK05 is a web-based cryptographic workstation and analysis platform. The evaluated snapshot includes a 10,000-entry catalog, code generation workflows, export tools, database-oriented features, authentication controls, QR and evidence functions, visual laboratories, and operational utilities. The platform is suitable for controlled demonstrations, prototyping, educational work, internal evaluation, and further security hardening.

This report documents observed implementation evidence and reproducible repository checks. It does not claim that every catalog name is a standardized cryptographic primitive, that every deployment is configured securely, or that the platform currently replaces a certified HSM, an independent audit, or a regulated security product.

Assessment conclusion

- Internal technical self-assessment: COMPLETED for the repository snapshot identified above.
- Reproducible enterprise self-test: PASSED for the checks listed in this report.
- Production certification status: NOT YET EXTERNALLY VALIDATED.
- Recommended next gate: independent application-security review and deployment hardening.

1. Scope and evidence basis

The assessment covers source files in the local repository and the automated enterprise self-test. Runtime environment settings in Render, third-party service accounts, infrastructure administration, and operational procedures must be verified separately in the deployed environment.

Application UI	app/app.jsx and browser bundle	Workstation interface, tools, exports, dialogs, labs
Server	server.js	HTTP routes, headers, authentication, persistence, audit, gateways
Catalog	data/catalog.js and data/generators.js	10,000 IDs and generator health checks
Automated test	scripts/enterprise-selftest.js	Known vectors and catalog/generator checks
Deployment	Environment-dependent	Requires separate Render configuration review

Repository integrity anchors

app/app.jsx	96F76B079C6E6E104B3C70FD2CDE996BF0D7B541FA8F7E72EDC0359164585706
server.js	6D301B965E70B3F376A8ADD25CC90CC2C907E0C7642D5B903CBFC5EC2A3443D4
data/catalog.js	90BDE5954339C6E1445C76BFFA7EA6722ECD0610DFBCD27731BE4044608EC1DF
scripts/enterprise-selftest.js	2538C9E8C774D4F29D7A1DE4B8E33A3BEA8EAE23D1FF096984FD6DADEBDB5B1B

Latest commit subject: Show saved code previews in parametric selector

2. Reproducible automated checks

The repository enterprise self-test was executed with: `npm run test:enterprise`. The following results were returned by the evaluated snapshot.

PASS	PASS sha256-known-vector
PASS	PASS hmac-sha256-known-vector
PASS	PASS pbkdf2-sha256-known-vector
PASS	PASS aes-gcm-known-vector
PASS	PASS catalog-unique-ids 10000 ids
PASS	PASS catalog-total-10000 10000/10000 ids
PASS	PASS neo-200-complete 200/200
PASS	PASS apex-300-complete 300/300
PASS	PASS hashcod-8282-complete 8282/8282
PASS	PASS neo-generator-health OCG-NEO.TOK.v11.N200-COLD-MQEBAE3UW3O4E
PASS	PASS apex-generator-health OCG-APEX.ANCH.v12.A300-ORACLE-X5PODXKAFPWO6PY3
PASS	PASS hashcod-10000-generator-health HASHCOD.PQS.v13.HC-PQC-SIG-Atlas-Sigma-08282-L3-v3.6
PASS	PASS jwt-real-shape
PASS	ENTERPRISE SELFTEST OK

Interpretation: these checks are meaningful regression evidence, but they are not a substitute for a full cryptographic module validation, third-party code review, fuzzing campaign, adversarial penetration test, or formal verification.

3. Security control matrix

Status definitions: IMPLEMENTED means the repository contains an active implementation path. CONFIGURABLE means the capability exists but requires deployment settings. PARTIAL means useful controls exist but the target assurance level is not yet complete. NOT VALIDATED means no independent certification evidence is claimed.

Password protection	IMPLEMENTED	Server hashes passwords with scrypt and random salt; legacy PBKDF2 verification remains supported.
Session cookies	IMPLEMENTED	HttpOnly and SameSite=Lax cookies; Secure flag enabled for production or forwarded HTTPS.
CSRF protection	IMPLEMENTED	Per-session CSRF token checked on protected mutation routes.
Rate limiting	IMPLEMENTED	IP and authenticated-user buckets with method-based limits and 429 responses.
Security headers	IMPLEMENTED	HSTS, X-Frame-Options DENY, nosniff, no-referrer, COOP, CORP, Permissions-Policy, CSP.
Encrypted local auth cache	IMPLEMENTED	AES-256-GCM envelope with random 96-bit IV and authentication tag.
Render PostgreSQL	CONFIGURABLE	DATABASE_URL activates PostgreSQL persistence; deployment environment must be reviewed.
OAuth / OIDC	CONFIGURABLE	Google, Microsoft and GitHub flows are present; provider credentials must be configured.
Audit records	PARTIAL	Security events are appended locally and synchronized to PostgreSQL when available.
Immutable hash-chained logs	PARTIAL	Append-style audit exists, but tamper-evident hash chaining is not demonstrated in server.js.
Automatic backups	PARTIAL	Daily best-effort local backups exist; restore drills and encrypted off-site retention need validation.
Secrets management	PARTIAL	Environment-variable support exists, but a production secret manager and rotation process are required.
CSP hardening	PARTIAL	CSP exists; unsafe-inline and unsafe-eval remain allowed because of current browser build dependencies.
MFA / passkeys	PARTIAL	Recommended for production; not demonstrated as an enforced account control in this snapshot.
HSM-backed key custody	NOT VALIDATED	No certified hardware-backed key management integration is claimed.
External penetration test	NOT VALIDATED	No independent penetration-test report is attached to this self-assessment.
FIPS 140-3 validation	NOT VALIDATED	No CMVP validation certificate is claimed for this application or module.
ISO/IEC 27001 certification	NOT VALIDATED	No accredited information-security management certificate is claimed.

4. Platform capability inventory

Core workstation	Generation, copied-code database, QR workflows, exports, Code GUI/CMD, IDE utilities.
Analysis laboratories	Parametric Analyzer, Pivot Kernel Crypto Lab, Complex Entropy Map, Graph Lab, Crypto Exam Suite.
Evidence and identity	Evidence Vault concepts, certificates, QR verification, tickets, fingerprints, client records.
Cryptographic experiments	LWE Lattice Lab, derivatives, geometric codes, BASEMAT-style mathematical tools.
Transport and phone flows	HNS/HOS/HCP concepts, HNS Browser, Phone OS link, SMS gateway paths.
Security utilities	Token Inspector, Secret Scanner, API Trust Score, File Integrity Monitor, Risk Engine, Developer Vault.
Business utilities	Quotation, billing timer, ticket forge, license factory, launch-center materials.

Cryptographic naming policy

The platform catalog includes standardized names, internal profiles, composite formats, experimental labels, educational artifacts, and generated variants. Internal or branded names must not be advertised as new proven cryptographic algorithms unless they receive public specification, expert review, reproducible testing, and appropriate external validation.

- Use established libraries and standards for security-critical production encryption.
- Treat visual metrics, entropy scores, parametric curves, and Pivot Kernel results as analysis aids, not proofs of security.
- Label experimental profiles clearly in UI, reports, exports, and commercial materials.
- Document formula inputs, thresholds, false-positive limits, and datasets for every proprietary metric.

5. Priority findings and corrective actions

P0	Rotate development fallback secret	server.js contains a development fallback for HASHCOD_SECRET.	Set a high-entropy HASHCOD_SECRET in Render and rotate it before external use.
P0	Protect gate and admin hashes operationally	Default hash constants are present as fallback values.	Move production values to environment variables and maintain a documented rotation procedure.
P1	Tighten browser CSP	Current CSP allows unsafe-inline and unsafe-eval for existing build dependencies.	Bundle frontend dependencies locally and remove unsafe directives where feasible.
P1	Add tamper-evident audit chaining	Audit events are append-oriented but not cryptographically chained.	Store prevHash and rowHash for every audit row; verify chain integrity during export.
P1	Verify PostgreSQL protection model	Render persistence stores structured JSON; local cache is AES-GCM protected.	Define encryption-at-rest responsibility, backup retention, access roles, and restore drills.
P1	Enforce MFA or WebAuthn for sensitive actions	Strong session controls exist, but a second factor is not demonstrated.	Require step-up authentication for admin actions, secret export, and key rotation.
P2	Expand automated tests	Known vectors and catalog checks pass.	Add API integration tests, auth negative cases, CSRF tests, file-upload tests, dependency scanning, and fuzzing.
P2	Commission independent review	This report is internal.	Request an external pentest and remediate findings before marketing enterprise assurance.

6. External assurance roadmap

1	Internal baseline	Maintain this signed snapshot report, automated tests, change log, and reproducible hashes.	Now
2	OWASP ASVS review	Map server and frontend controls against OWASP ASVS requirements and record evidence per control.	Next
3	Independent pentest	Engage an external application-security reviewer for authenticated and unauthenticated testing.	Before broad launch
4	Operational hardening	Document incident response, backups, secret rotation, deployment approvals, and restore exercises.	Before customer data
5	ISO/IEC 27001 path	If selling enterprise services, build an ISMS and work with an accredited certification body.	Business decision
6	FIPS 140-3 path	Only if offering a cryptographic module requiring validation: work with an accredited lab and CMVP.	Product decision
7	HSM integration	For regulated key custody, integrate an appropriate HSM/KMS rather than claiming software equivalence.	Enterprise tier

Suggested public wording

"Q+7LkMK05 maintains an internal technical self-assessment with reproducible repository checks. External certification and independent penetration testing remain separate assurance activities."

7. Standards and authoritative references

OWASP Application Security Verification Standard (ASVS)	https://owasp.org/www-project-application-security-verification-standard/
NIST Cryptographic Module Validation Program (CMVP)	https://csrc.nist.gov/projects/cryptographic-module-validation-program
NIST FIPS 140-3 standard	https://csrc.nist.gov/pubs/fips/140-3/final
ODAC - Que es acreditacion	https://odac.gob.do/que-es-acreditacion/
ODAC - Laboratorios bajo NORDOM ISO/IEC 17025:2017	https://odac.gob.do/todos-los-servicios/acreditacion-de-laboratorios-de-ensayo-y-calibracion-bajo-la-norma-nordom-iso-iec-170252017/
ISO/IEC 27001 information security management systems	https://www.iso.org/standard/27001
AICPA SOC for Service Organizations	https://www.aicpa-cima.com/topic/audit-assurance/audit-and-assurance-greater-than-soc-2

Detached integrity verification

A companion .sha256 file is generated beside this PDF. Verify it before distribution or archival. The companion file contains the SHA-256 digest of the final PDF and can be checked independently with standard operating-system tools.

Sign-off

Issued by	Q+7LkMK05 Project - Internal Technical Self-Assessment
Snapshot	1d727f3a6086f251b267ca49211620eb2907d86b
Report ID	Q7-SELF-20260531-BDCEB8FA
Qualification	Internal evidence report only. External certification not claimed.